

Information Security Policy

Policy Category: Information Security & Identity Governance

Document ID	POL-SEC-01	Effective Date	15 Jan 2026
Version	3.2	Review Date	15 Jan 2027
Status	Approved	Classification	Internal
Owner	Chief Information Security Officer	Approved By	Risk & Compliance Committee
Supersedes	POL-SEC-01 v3.1		

1. PURPOSE

This policy establishes the mandatory information security requirements across all Acme Corporation environments to protect corporate assets, customer data, and infrastructure against unauthorized access, disclosure, or destruction.

2. SCOPE

This policy applies to all employees, contractors, third-party vendors, systems, cloud infrastructures, and physical facilities operated by or on behalf of Acme Corporation.

3. DEFINITIONS

- **Restricted Information:** Highly sensitive data including source code, executive communications, financial ledgers, and Tier-1 personal data.
- **Privileged Account:** Any user or service account with elevated system access rights, including root, administrator, and deployment credentials.
- **Compensating Control:** An alternative security measure designed to satisfy the requirement of a baseline control when technical limitations prevent direct compliance.

4. POLICY / REQUIREMENTS

SEC-AC-001: Privileged accounts MUST use phishing-resistant MFA (hardware tokens or FIDO2 keys).

SEC-AC-002: Privileged access MUST use just-in-time (JIT) provisioning.

SEC-AC-003: Administrative sessions MUST NOT exceed 4 hours.

SEC-AC-004: Access reviews MUST be performed monthly for privileged accounts.

SEC-AC-005: Terminated user access **MUST** be revoked within 4 hours.

SEC-EN-001: Data at rest containing Restricted information **MUST** be encrypted using AES-256.

SEC-EN-002: Cryptographic keys protecting Restricted information **MUST** undergo key rotation every 365 days.

SEC-EN-003: Data in transit across external networks **MUST** use TLS 1.3.

SEC-LG-001: Security audit logs **MUST** be retained for 180 days in an immutable state.

5. ROLES & RESPONSIBILITIES

- **Chief Information Security Officer (CISO):** Ultimate owner of POL-SEC-01 and final approver of all security exceptions.
- **System Administrators:** Responsible for implementing JIT provisioning, MFA, and access control configurations.
- **Employees & Contractors:** Obligated to adhere to credential hygiene, immediate reporting requirements, and usage guidelines.

6. CONTROL REQUIREMENTS

All asset owners must conduct continuous automated monitoring against SEC-AC-001 through SEC-LG-001. Any deviation constitutes a high-severity compliance finding.

7. EXCEPTIONS

- Legacy systems incapable of supporting MFA may receive an exception for up to 90 days with CISO approval and compensating controls.
- Exception requests must be submitted via the Governance Portal containing risk assessments and remediation roadmaps.

8. MONITORING & COMPLIANCE

Compliance teams will audit access and encryption controls on a quarterly basis. Automated logging failures trigger immediate P2 alerts.

9. RECORDS / EVIDENCE

- Access review audit sign-offs must be stored in the corporate governance repository.
- Exception approval tickets must be archived for a minimum duration matching the exception lifecycle plus 1 year.

10. INCIDENT / ESCALATION REQUIREMENTS

Security incidents involving Restricted information must be reported to Security within 30 minutes. Cross-reference PROC-IR-01 for full severity workflows.

11. REVIEW & GOVERNANCE

This policy is subject to annual review by the Risk & Compliance Committee or immediately following any critical security audit failure.

12. REFERENCES

- National Institute of Standards and Technology (NIST) SP 800-53 Rev. 5
- ISO/IEC 27001:2022 Controls Framework

13. CROSS-REFERENCES

- STD-PRV-02 (Data Protection & Privacy Standard)
- STD-TPM-03 (Third-Party Risk Management Standard)
- PROC-IR-01 (Security Incident Response Procedure)
- POL-REC-01 (Records Retention & Legal Hold Policy)

APPENDIX A — CONTROL MATRIX

Control ID	Domain	Requirement Summary	Enforcement Mechanism
SEC-AC-001	IAM	Phishing-Resistant MFA	Mandatory (IdP Config)
SEC-AC-003	IAM	Max 4-hour Admin Session	Automated Timeout

APPENDIX B — DEFINITIONS

See Section 3 for full definitions.

APPENDIX C — EXCEPTION CATEGORIES

Category 1: Legacy Technical Incompatibility
Category 2: Third-Party Operational Constraints